

Threat Intelligence Brief: Qilin Ransomware Targeting the Financial Sector

Classification: TLP:CLEAR (public distribution) **Author:** Kethan Umanarayanan **Date:** July 2026 **Report type:** Open-source threat intelligence brief **Confidence:** Moderate — assessed from open-source intelligence (OSINT) and vendor reporting. No primary incident-response data.

1. Executive Summary

Qilin is currently the most active ransomware operation in the world, and it is a direct and growing threat to financial institutions. After law enforcement dismantled rival groups such as LockBit and ALPHV/BlackCat in 2024, Qilin aggressively expanded into the gap they left behind, claiming over 1,000 victims in 2025 and more than 500 additional victims in the first half of 2026 alone.

What makes Qilin especially dangerous to banks, credit unions, and investment firms is *how* it gets in. Rather than relying on noisy malware, Qilin's affiliates most often log in using **valid, stolen credentials** through exposed VPN and remote-desktop services. To a defender, the initial break-in looks like a normal employee signing in — which is why these intrusions frequently go undetected for long periods before the ransomware is triggered. For a financial institution, where a single compromised administrator account can expose customer records, payment systems, and account data, this is a worst-case entry method.

Qilin also uses **double extortion**: it steals data before encrypting it, then threatens to publish that data on its leak site if the ransom is not paid. For a regulated financial firm, the data-leak threat can be more damaging than the encryption itself, because it triggers breach-disclosure obligations, regulatory scrutiny, and lasting reputational harm.

The good news is that Qilin's core techniques are well understood and largely preventable with disciplined identity controls. This brief describes the group, maps its tactics to the MITRE ATT&CK framework, lists indicators of compromise, and provides prioritized, practical recommendations a financial institution can act on.

2. Actor Profile

Names / aliases: Qilin (current), formerly "Agenda" **First observed:** Mid-2022 (as Agenda) **Suspected origin:** Russia-based. The operation excludes Commonwealth of Independent States (CIS) countries from targeting, a pattern common among Russian-speaking ransomware groups. **Operating model:** Ransomware-as-a-Service (RaaS) **Motivation:** Financially motivated (extortion)

Qilin runs a **Ransomware-as-a-Service** model. A small core team develops and maintains the ransomware and supporting infrastructure, while independent "affiliates" carry out the actual intrusions in exchange for a large share of each ransom — reportedly 80–85%. This division of labor lets the operation run far more attacks at once than a single closed team could, and it means that no two Qilin intrusions look exactly alike: different affiliates use different access methods and tooling, so defenders cannot rely on a single fixed signature.

Technically, Qilin has matured over time. It began as a Go-based encryptor and was rewritten in **Rust**, which is harder for antivirus engines to analyze and makes it easier to build versions for **Windows, Linux, and VMware ESXi** environments — the last of which lets a single attack encrypt many virtual machines at once. The group has continued to add pressure tactics beyond simple encryption, including a data-leak site, DDoS threats, and even a "Call Lawyer" negotiation feature designed to intimidate victims into paying.

Relevance to the financial sector. Qilin is broadly opportunistic — its most-hit sectors include manufacturing, professional services, and healthcare — but its favored techniques map precisely onto the weak points that matter most for financial institutions: exposed remote access, reused or stolen credentials, and valuable data suited to extortion. Analysts also note that Qilin has been adopted by more advanced actors; Microsoft observed the North Korea-linked group Moonstone Sleet deploying Qilin ransomware in 2025, meaning a "Qilin" intrusion is not always run by an ordinary criminal affiliate. Because financial institutions sit near payment infrastructure and hold high-value personal and account data, they represent exactly the kind of high-pressure, high-payout target the RaaS model is built to exploit.

3. Tactics, Techniques, and Procedures (TTPs)

The table below maps Qilin's commonly observed behavior to the MITRE ATT&CK framework. Not every affiliate uses every technique, but these represent the most consistently reported patterns across public analysis.

Tactic	Technique	ATT&CK ID	How Qilin uses it
Initial Access	Valid Accounts	T1078	Logs in with stolen/purchased credentials via exposed RDP and VPN portals — the most common entry point.
Initial Access	Exploit Public-Facing Application	T1190	Exploits known vulnerabilities in internet-facing appliances (e.g., Fortinet, Veeam Backup & Replication, JetBrains TeamCity).
Initial Access	Phishing	T1566	Spear-phishing to deliver credential harvesters and loaders as a secondary vector.
Execution	Command and Scripting Interpreter: PowerShell	T1059.001	Runs PowerShell and command-line scripts during deployment.
Persistence	Registry Run Keys / Startup Folder	T1547.001	Establishes persistence to survive reboots.
Persistence	Winlogon Helper DLL	T1547.004	Alternate persistence mechanism.
Privilege Escalation	Access Token Manipulation	T1134	Manipulates access tokens to elevate and move laterally.
Credential Access	Credentials from Password Stores: Chrome	T1555.003	Harvests credentials stored in Google Chrome before encryption.
Credential Access	OS Credential Dumping	T1003	Uses tools such as Mimikatz to extract credentials.
Defense Evasion	Impair Defenses: Disable Security Tools	T1562.001	Terminates antivirus/EDR; has abused Windows Subsystem for Linux (WSL) to run Linux encryptors on Windows hosts and evade EDR.
Defense Evasion	Indicator Removal: Clear Windows Event Logs	T1070.001	Deletes system logs before encryption to frustrate investigation.
Discovery	Network Share / Remote System Discovery	T1135, T1018	Maps internal assets to identify high-value targets.
Lateral Movement	Remote Services (RDP / SMB / PsExec)	T1021	Moves across the network using legitimate remote-access tools.
Exfiltration	Exfiltration Over Web Services	T1567	Stages and steals data (e.g., via WinSCP, Cyberduck) prior to encryption for double extortion.

Tactic	Technique	ATT&CK ID	How Qilin uses it
Impact	Data Encrypted for Impact	T1486	Encrypts files across Windows, Linux, and ESXi.
Impact	Inhibit System Recovery	T1490	Deletes Volume Shadow Copies (VSS) to block easy recovery.

The typical intrusion, in plain terms: an affiliate obtains valid credentials (bought, phished, or from an exposed service) and logs in as a real user. Once inside, they quietly map the network, dump additional credentials, and escalate privileges — often "living off the land" with legitimate IT tools to avoid detection. They disable security tooling and clear logs, exfiltrate the most sensitive data, delete backups and shadow copies, and only then deploy the ransomware. By the time the ransom note appears, the damage — stolen data plus destroyed recovery options — is already done.

4. Indicators of Compromise (IOCs)

Important caveat: ransomware IOCs (file hashes, IPs, filenames) change constantly and are affiliate-specific, so they are useful for detection but should never be a defender's primary control. Behavioral detection of the TTPs above is far more durable. The most reliable, continuously updated technical IOCs should be pulled from authoritative feeds such as CISA advisories and the tracking sites listed in the References. Representative **behavioral** indicators reported across Qilin campaigns include:

- VPN or RDP logins from unusual geolocations or at unusual times, especially to privileged accounts
- Installation of remote-management tools (AnyDesk, ScreenConnect, Splashtop) outside approved IT workflows
- `wsl.exe --install` or `wsl.exe -e` executed on systems that have no development purpose
- Execution of credential-dumping tooling (e.g., Mimikatz) or Chrome credential-store access
- Mass deletion of Volume Shadow Copies and clearing of Windows event logs
- Ransom note files written to directories such as `C:\temp`; unexpected file-extension changes across shares

A machine-readable starter set of these behavioral indicators is provided in [./ioc/qilin-iocs.csv](#).

5. Detection and Mitigation Recommendations

These are prioritized for a resource-conscious financial institution. The theme is deliberate: Qilin's primary strength is identity abuse, so identity controls give the highest return.

Priority 1 — Close the identity front door. - Enforce phishing-resistant **multi-factor authentication (MFA)** on all remote access (VPN, RDP) and every privileged account, with no exceptions. This single control defeats Qilin's most common entry method (T1078). - Eliminate direct internet-exposed RDP; place remote access behind a VPN or zero-trust gateway. - Continuously monitor for leaked/for-sale corporate credentials and force resets when found.

Priority 2 — Patch the exposed edge. - Prioritize patching of internet-facing appliances Qilin is known to exploit (Fortinet, Veeam, TeamCity and similar). Track them against CISA's Known Exploited Vulnerabilities catalog and patch KEV-listed flaws first (T1190).

Priority 3 — Make recovery survivable. - Maintain **immutable, offline backups** that cannot be deleted by an intruder, and test restoration regularly. This directly counters Qilin's shadow-copy deletion (T1490) and reduces extortion leverage.

Priority 4 — Detect the behavior, not just the file. - Deploy EDR tuned to alert on credential dumping, security-tool tampering, mass log/VSS deletion, and unauthorized WSL use (T1562, T1070, T1490). - Alert on RMM tools appearing outside approved change workflows. - In a SIEM, watch for impossible-travel logins and privileged sign-ins from atypical locations.

Priority 5 — Reduce blast radius and rehearse. - Apply least-privilege access and network segmentation so a single compromised account cannot reach the entire environment. - Run a tabletop exercise covering a double-extortion scenario, including the legal/disclosure decisions unique to a regulated financial firm.

A note on realistic expectations: no control set makes an organization immune, and Qilin's affiliates adapt their tooling frequently. These measures are intended to *reduce the likelihood and impact* of a Qilin intrusion by removing the group's preferred paths, not to guarantee prevention.

6. References

1. MOXFIVE — *Qilin Ransomware 2026: TTPs, Victims and Defense Guide*. <https://www.moxfive.com/blog/qilin-ransomware-2026-ttps-victims-and-defense-guide>
2. Picus Security — *Qilin Ransomware Analysis: Critical TTPs and Defense*. <https://www.picussecurity.com/resource/blog/qilin-ransomware>
3. NetSecurity — *Qilin Ransomware Chaos: Tradecraft, Scale, and What Defenders Should Do Now*. <https://www.netsecurity.com/qilin-ransomware-chaos-understanding-tradecraft-scale-and-what-defenders-should-do-now/>
4. Qualys — *Qilin Ransomware Explained: Threats, Risks, Defenses*. <https://blog.qualys.com/vulnerabilities-threat-research/2025/06/18/qilin-ransomware-explained-threats-risks-defenses>
5. CybelAngel — *Qilin Ransomware: Attack Methods and 2026 Status*. <https://cybelangel.com/blog/qilin-ransomware-tactics-attack/>
6. Group-IB — *Qilin Ransomware*. <https://www.group-ib.com/blog/qilin-ransomware/>
7. GuardSix — *Qilin (formerly Agenda): From Emergence to Global Ransomware Dominance*. <https://guardsix.com/blog/qilin-from-emergence-to-global-ransomware-dominance>
8. dexpose — *Qilin Ransomware: Group Profile, TTPs, IOCs & Defense (2026)*. <https://www.dexpose.io/qilin-ransomware/>
9. Black Kite — *2026 Financial Services Cybersecurity Report*. <https://blackkite.com/reports/2026-financial-services-report>
10. MITRE ATT&CK — Enterprise technique reference. <https://attack.mitre.org/>

This brief is an educational open-source intelligence product created for a professional security portfolio. It contains no confidential or non-public information. All findings are drawn from publicly available reporting cited above, and technique mappings follow the MITRE ATT&CK framework.